Threat Intelligence

Threat Evolution in Q3 2019

October 2019

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Threats to the government sector 5

Data leaks 6

FORECASTS FOR Q4 2019 **7**

ADVANCED THREATS IN THE FINANCIAL SECTOR **8**

FINANCIAL THREATS **12**

Malware for Android 13

Threats and malware for PC 15

Attacks on ATMs and POS terminals 24

Malware for Linux 26

STATE-SPONSORED APTS **27**

DATA LEAKS **44**

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q3 2019 saw the following APT campaigns against financial organizations:

- In late June 2019, specialists discovered files used by the FIN7 group (Russia) to distribute the Griffon malware.
- The Cobalt group is more active compared to the previous quarter. They sent out documents with macros under the name of Barclays bank. The group also sent out an encrypted archive with an executable within from the address Sergey.Sonin@vnukovo.ru, emails with malicious links to banks, and files disguised as legitimate browser installers. All these attacks distributed the Coblnt malware.
- Group-IB established that the Silence group carried out targeted attacks on banks in Latin America, Eastern Europe, and Asia using new tools: APT.Silence.EDA.ps1 and EmpireDNSAgent.
- Lazarus (North Korea) carried out a campaign called Operation Movie Coin, which targeted cryptocurrency traders in South Korea. In addition, previously unobserved samples of the well-known HOPLIGHT Trojan were found. Further, ATMDtrack Trojan was discovered. The Trojan is used for reading the data of bank cards inserted in ATMs.
- FIN8 resumed their activities and upgraded their arsenal, which now includes Badhatch, a malicious program designed for reconnaissance. The threat actors used it to install the PoSlurp malware, whose purpose is to intercept payment card data that go through POS terminals.

Financial threats

- JS sniffers continue to be actively used to compromise bank cards. In Q3 2019, Group-IB Intelligence detected the use of sniffer families such as Inter, Voldemort, PostEval, and others. The FakeSecurity sniffer and attacks it was involved in were analyzed individually.
- The FIN8 group upgraded its tool for attacks on POS terminals. The tool was named Badhatch.
- POS terminals at Hy-Vee supermarkets and restaurants as well as at Russell Stover's Chocolates in the US were found to have been hacked resulting in bank card compromise.
- A previously known Trojan called MagicPOS continues to be sold on underground resources.
- POS terminals at Emporium Rodrigues stores, a chain of supermarkets in Brazil, were compromised, Group-IB's analysis of underground sources revealed.
- In September 2019, it was reported that Lazarus could be behind ATMDtrack, a malicious program designed for attacks on ATMs.
- The source code of LsBot, a linux Trojan, was put up for sale on underground platforms.
- A new banking Trojan for Android called Cerberus was put up for sale. The Trojan has extensive functionality.
- RTM, a banking Trojan, continues to be sent out to targets in Russia and certain other post-Soviet countries.
- FlexNet remains the most active banking Trojan for Android in Russia.
- The source code of the Android banking Trojan Anubis (version 2.5) is sold on underground forums.
- The source code of Titan bot, a banking Trojan for Windows, was published.

- A new loader for Windows called Buer Loader was found to have been put up for sale.
- An LPE exploit for CVE-2019-1069 was put up for sale on underground forums. It may be used in targeted attacks.
- TrickBot was detected in Australia, Canada, Spain, Germany, and the US. The malware started stealing data from the accounts of US mobile operators with the aim of gaining control over victims' SIM cards and phone numbers.
- ISFB (Gozi) attacks were detected in Canada and the US. The malware also attacks Australia, Italy, Germany, and Poland.
- The modular banking Trojan Danabot was found to have been used in attacks on banks in Australia, the US, and Poland.
- Gootkit samples were used in attacks on banks in France, Italy, Poland, Austria, Germany, Portugal, and the US.
- Compared with Q2, the focus of IcedID has not changed. Its targets are based in the US, Canada, and the UK.
- Ramnit continues to be used in attacks against US and Japanese targets.
- We observed a significant decline in the number of attacks involving Backswap.

Threats to the government sector

Governments are always going to be under the threat of cyberespionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. The following APT campaigns against government organizations were detected in Q3 2019:

- A global campaign called Soft Cell was discovered. The campaign has targeted telecommunications operators since 2012 and is believed to be the work of APT10 (China).
- Turla is using new malware: KopiLuwak analogues (.NET RocketMan, PowerShell MiamiBeach) and Topinambour in their attacks on government organizations.
- The DarkHotel group (North Korea) attacked leaders of Chinese trade organizations.
- APT28 (Russia) carried out an attack against the Ministry of Foreign Affairs of Ukraine using Zebrocy, a malicious program based on the Nim programming language.
- An attack involving IoT (Internet of Things) devices was detected. It is attributed to the APT28 group (Russia), but it is possible that the BlackEnergy group (Russia) is behind it.
- In late June 2019, the APT34 group (Iran) carried out a phishing campaign targeting oil and gas, energy, utilities and government industries.
- Ratsniff, a previously unknown tool used by OceanLotus (Vietnam) since 2016, was discovered. In August 2019, the group carried out attacks on Cambodian and Vietnamese government agencies.
- Late July 2019 saw the publication of information on attacks carried out by the Dragonfly group (Russia) in March 2017. In addition, an analysis of an updated version of the Karagany backdoor (which the group used in their attacks in 2017-18) was released.
- At the end of Q3 2019, the MuddyWater group (Iran) resumed sending out lure documents targeting Tajikistan, Azerbaijan, and Iran.
- In early July 2019, the US Cyber Command uploaded samples of the APT33 group's malware. The samples are related to the group's activity in 2016-17.
- A version of the Okrum backdoor was discovered. The backdoor was used in 2017 by APT15 (China) to attack diplomats.
- The Sea Turtle campaign continues to spread around the globe and has had its DNS hijacking techniques updated.

- A Pakistani hacker group called Gorgon Group continued attacking the government sector around the world and added international foreign trade organizations to the list of their targets.
- TA428 (China) targeted a number of government organizations in East Asia as part of their Operation LagTIme IT campaign that involved the new Cotx RAT.
- The activities of a new group called HEXANE were discovered. HEXANE targets industrial and telecommunications companies in Africa, the Middle East, and Central Asia.
- Gamaredon Group are testing new malware—this time designed for Linux—called EvilGnome.
- Kimsuky hackers (North Korea) are not slowing down. The group launched a campaign against retired South Korean diplomats, as well as the ministries of foreign affairs of France, the US, and the UK.
- Q3 2019 saw the compilation of information on the APT41 group (China), which has been active since 2012 and includes Winnti and Barium, groups that had previously been considered separate.
- APT37 (North Korea) continues their malicious actions against South Korea and started spying on their victim's calls using mobile Trojans.
- Stealth Falcon (UAE) started using a new backdoor and Background Intelligent Transfer Service (BITS), an unusual way of communicating with the C&C server, in their attacks on Middle Eastern diplomatic missions.
- A previously unstudied group called Tortoiseshell has attacked 11 Saudi Arabia–based IT providers since July 2018.
- Hackers from BITTER (India) are conducting a large-scale campaign against Chinese government organizations.
- Patchwork, an Indian hacker group, is carrying out an espionage campaign against Pakistan, reusing the Kashmir issue as a way to fuel conflict.
- Emissary Panda (China) is not slowing down and carries out new attacks using a compromised (or issued) certificate of a Chinese software company.
- The activity of Poison Carp, a Chinese hacker group, was discovered. The group uses WhatsApp, as well as Android and iOS vulnerabilities to target senior members of Tibetan groups.
- Rancor (China) is carrying out a new espionage campaign against South-East Asia using an RTF document to exploit CVE-2018-0798.

Data leaks

- The Indonesian airline Lion Air experienced a major data breach. The data were stored on an unprotected server and could be accessed without authorization.
- The data of a large part of Ecuador's population were also stored on an unprotected server.
- A major breach of customer data occurred at Sephora, a chain of personal care and beauty stores. A total of about 3 million entries were compromised.
- Capital One, a US bank, suffered a data leak in March 2019 that affected over 100 million people, it was reported.
- A threat actor who goes by the alias 0v1ru$ hacked SyTech, an FSB (Russia's Federal Security Service) contractor.
- Imperva, a cybersecurity and DDoS mitigation company, reported that the data of its customers had been compromised.

Forecasts for Q4 2019

- Silence is becoming one of the most active and aggressive financially motivated hacking groups out there. New Silence attacks can be expected in the APAC region. We believe that the threat actor may send out "recon" emails with no malicious payload in order to conduct reconnaissance, expand the geographical scope of their attacks, and understand what cybersecurity solutions are used in a particular bank. The recon mail-outs result in the creation of a "target" list of email addresses that will be used for mail-outs with malicious attachments. We also believe that Silence imitators may start to operate in Russia and other post-Soviet countries.
- Credit card sniffers and attacks on POS terminals will remain relevant. There is an increasing number of new malicious programs designed for these purposes. We believe that at the end of Q4 2019, the number of cases of bank card compromise will increase before Christmas and New Year holidays.
- Attacks on healthcare organizations involving ransomware and spyware will continue. Most of them will be more professional than the CloudMid attacks.
- Servers where the CobaltSrike framework was detected may be used in targeted attacks on financial organizations. The group behind the preparations for the attacks have not yet been identified.
- There may be attacks on Linux users resulting from the LsBot Linux bot having been put up for sale.
- Considering the sale of the source code of Anubis, an Android banking Trojan, we believe that it will be actively used for theft purposes in the near future. We should note that the malware does not work in post-Soviet countries, which means that Europe, Australia, and North America are at highest risk.
- Cerberus, an Android banking Trojan, will be used in attacks on bank customers in Europe, North America, and, possibly, Australia.
- FlexNet will be the most active banking Trojan for Android in Russia.
- We forecast that the publication of Titan bot's source code will prompt the appearance of new versions of this malware, including sale and rent offers on underground resources and an increase in the number of attacks.
- Trickbot started stealing US mobile operators' account data. We believe that the geography of these attacks may expand and affect mobile operators in other countries too, primarily in Europe. This will enable the attackers to gain control over their victims' SIM cards and phone numbers, allowing them to carry out other fraudulent operations. The malware will also be used in attacks on banks in Australia, North America, and Europe.
- Gozi will be an active threat in the US, Canada, Australia, Italy, Germany, and Poland. The geography of its attacks on banks in Europe may expand.
- Gootkit will continue to target European banks.
- Ramnit will pose a threat to Japan.
- IcedID attacks will continue in the US and Canada, but are also possible in Europe.
- Danabot will be the biggest threat to Australia.

Advanced threats in the financial sector

333

APT name	Regions attacked	Operation start
FIN7	Global	May 2018

Since at least May 2018, FIN7 has been registering domains with the same pattern (the same registration data, similar names *-cdn.com), which may have been used in their attacks. In late June 2019, specialists discovered files that interacted with one of these domains, which means they can be associated with FIN7. These are password-protected .xlsb files with a macro that are distributed through phishing and used for downloading the Griffon malware. The threat actors already used the C&C domain in early June to distribute the same malware.

FIN7 is a financially motivated Russian-speaking criminal group that has been active since 2015. The threat actors use social engineering techniques and periodically update their attack methods and tools in an effort to bypass detection mechanisms. Most of their attacks target hospitality and restaurant businesses in Europe and the US.

APT name	Regions attacked	Related notifications	Operation start
Cobalt	Global	CP-1438-72 — CP-1438-75	2016

In Q3 2019, Cobalt carried out several malicious email campaigns. All of the attacks involved the CobInt malware being installed as the final payload:

- On June 12, 2019, the group allegedly sent out emails under the name of Barclays bank. The mail-out distributed documents containing a macro, which was used for downloading CobInt stager from the server. In addition, a number of other similar documents containing CobInt stager–downloading macros were discovered.
- On July 24, 2019, Cobalt sent out emails with an encrypted archive to Russian organizations from the address Sergey.Sonin@vnukovo.ru. The archive contained an executable file in .scr format classified as CobInt stager.
- On August 15, 2019, CobInt stager samples were uploaded to VirusTotal. The threat actors started the attack by sending a document with a macro, which once enabled downloads CobInt stager from a compromised server of a legitimate website. The files were uploaded through the web interface from Moldova.
- On August 20 and 23, 2019, Cobalt launched large-scale attacks on banks. The subjects of their emails were “Thank you for requesting an account” and “To complete the account creation.” One of the campaigns involved an email with two links to malicious files that downloaded the same CobInt Stager. The only difference was that one was PowerShell-based payload, while the other was based on JavaScript.
- In addition, on August 23, 2019 there were attacks with executable files disguised as legitimate Google Chrome, Firefox and Opera installers. In all three cases, executing them downloaded the file that is the CobInt stager.
- We also detected this Cobalt gang used More_eggs backdoor JScript backdoor (also known as Terra Loader or SpicyOmelette). The Trojan is sold on underground forums as malware-as-a-service (MaaS).

Cobalt is a Russian-speaking cybercriminal group active since April 2016. Their attacks target the internal infrastructure of banks and organizations that have common infrastructure with banks (leasing and

insurance companies) in Eastern Europe, post-Soviet countries, the Asia-Pacific region, and other areas. Their aim is to gain access to ATM, bank card, and interbank transfer management systems. To carry out their attacks, the group mostly uses phishing emails disguised as coming from financial organizations and ATM manufacturers. The emails contain malicious attachments in the form of a document with an exploit or a password-protected archive with an executable file within.

APT name	Regions attacked	Related notifications	Operation start
Silence	Chile, Costa Rica, Bulgaria, Global	CP-1645-22 — CP-1645-23	2016

On June 23, 2019, Group-IB specialists recorded an attack on banks in Chile, Costa Rica, and Bulgaria. The attacks involved a new tool, which is downloaded by the main Trojan Silence.Main and based on the Empire and dnscat2 open-source projects for penetration testing. The tool was named EmpireDNSAgent or EDA.

EDA has only 24 functions, 23 of which are borrowed from dnscat2 with some changes (dnscat2 has a total of 37 functions). The other function is a command handler from Empire. Communication with the C&C is performed through nslookup, a command-line tool. The agent requests a TXT record from the operator's DNS server and receives a command to execute. Unlike dnscat2, information is only encoded, instead of being encrypted.

The file “lisk.ps1” is a PowerShell script and is classified as the APT.Silence.EDA.ps1 agent. The program is designed to remotely control compromised systems via the DNS protocol and supports the following commands: changing the C&C address, downloading files from the network, sending a local file to the C&C server, executing commands in the cmd.exe command shell, collecting system information, rebooting and shutting down the system, and tunnelling traffic.

To transfer data, the group uses a legitimate DNS server of a hospital in Europe.

In August 2019, Group-IB specialists established that Silence carries out targeted attacks on banks in Latin America, Eastern Europe, and Asia.

Silence is a financially motivated cybercriminal group active since 2016. Their attacks are mostly targeted at post-Soviet countries, but the group has been gradually going global.

APT name	Regions attacked	Operation start
Lazarus	South Korea, India, Global	May 2017

In June-August 2019, Lazarus conducted Operation Movie Coin, a campaign against cryptocurrency traders. The group sent out emails exploiting a vulnerability in HWP (Hangul Word Processor). The internal structure of HWP reveals malicious PostScript “BIN0001.PS” in the BinData stream.

The malicious PostScript contains an encoded hexadecimal code and decrypts it with a XOR key that consists of 16 bytes. The shellcode attempts to download additional malicious files through C&C servers.

The C&C servers were WordPress-based websites and the attackers exploited the vulnerability to access the server.

In September 2019, 11 malware samples believed to be linked to Lazarus were uploaded to VirusTotal by US-CERT.

Some of the samples are related to the HOPLIGHT Trojan, which is designed to collect information about its victims' operating systems. To communicate with the attackers the Trojan uses a public SSL certificate. This malware was discovered in April 2019.

In September 2019, it was revealed that Lazarus could be behind the ATMDtrack and Dtrack RAT malware. It was established that ATMDtrack was used in the late summer of 2018 against Indian financial organizations. Analysis revealed that the threat actors incorporated the Trojan into ATMs, where it recorded information about inserted cards and saved it on the attackers' resources.

Researches have pointed out that Dtrack dropper's payload has similarities with the DarkSeoul campaign, dating back to 2013 and attributed to Lazarus. It is likely that the threat actors reused part of their old code to attack the financial sector and research centers in India.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. It has been established that the members of this hacking group are from North Korea.

APT name	Regions attacked	Operation start
FIN8	Global	2016

FIN8 upgraded their arsenal and resumed attacks aimed at stealing payment card information.

Gigamon researchers discovered Badhatch malware, which has not featured anywhere before.

The analysts say Badhatch is delivered to targeted devices through a Word document with a malicious macro. Opening it leads to successive downloads of PowerShell scripts with shellcode. The first-stage script copies its code into the existing PowerShell process and then loads a DLL (designed to communicate with the C&C server) into the same memory space. Next, the malware implements an asynchronous TLS-wrapped TCP/IP channel and delivers additional modules.

One of the downloaded components was named PoSlurp. It is designed to retrieve 15- or 16-digit bank card numbers.

FIN8 is a financially motivated group known for launching specialized campaigns to steal payment card information. The group targets retailers, restaurants, and hospitality businesses.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked	Related notification
Cerberus	June 2019	Global	CP-1950

An Android banking Trojan called Cerberus was put up for rent on an underground forum. The seller is known under the nickname ANDROID. They wrote that the program can perform the following:

- Covertly intercept, send and delete SMS messages
- Lock the device
- Log keystrokes (Messenger, Telegram, What'sApp, banking apps)
- Send USSD requests
- Redirect calls
- Open fake banking webpages
- Launch any application on the device
- Show push notifications of banking apps (Auto Push)
- Open URLs in the browser
- Obtain all contacts and SMS messages
- Install and delete any app
- Collect all card numbers on the device
- Obtain all emails on the device (Mail Grabber)
- Disable Google Play Protect and turn off after a time period specified in the admin panel.
- Support web fakes (web injects) for banking apps, social media, and Play Store; obtain authentication data and card information and transfer all compromised information to the admin panel
- Support additional domains (to connect to the server)
- Use an anti-emulation technique

The author also mentioned the features of the bots that are used together with the malware:

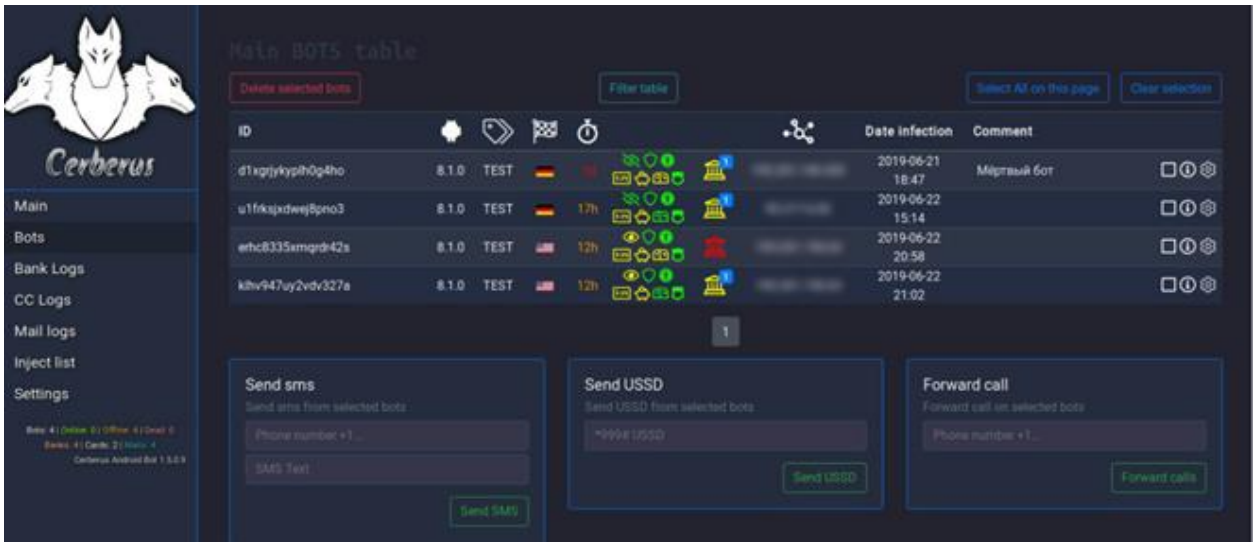
- The size of bot applications is between 125 and 180 KB (about 1 MB after encryption)
- Work on Android 5 and later
- Data transferred between the server and the bot is RC4 + base64–encrypted with a random key.
- Prevent the bot from being deleted, administrator rights from being disabled, and Accessibility Service from being turned off.
- Multilanguage support.

In addition, the threat actor described admin panel features:

A list of bots and infected devices with the following details: device status, time of infection, administrator rights status, country and language, bank logs status, status of email and card logs, device IP address, device model, phone activity detection (anti-emulation), phone number, and operator.

- Bot table filtering
- Adding self-made injects through the interface
- Uploading injects in HTML format.

- Bot operation statistics
- The panel is located in the TOR network on the author's server.



Cerberus admin panel.

Threat name	Detection	Regions attacked
Anubis	2017	Global

The Anubis malware for Android devices has been developed by a Russian-speaking virus writer with the nickname maza-in. There are no topics about the sale of the malware on underground forums. Potential clients receive detailed information about the banking Trojan by contacting its author via personal messages on Exploit, an underground forum. In forum discussions about the malware, users often note the developer's high professional skills and write that Anubis is the best Android Trojan on the market. In most cases, maza-in asks the forum administration to delete these discussions in order not to attract attention. Anubis was first mentioned as early as 2017.

Anubis has lately been distributed via Google Play through light downloader apps, which are not detected by antivirus solutions and are masqueraded as legitimate software. Upon installation, these malicious apps download the actual payload, which is classified as Anubis, and install it disguised as Flash Player or Google Play Protect.

The list of targets—which are mostly banks—is quite extensive and includes many countries.

The application has extensive functionality. Once it is granted all necessary rights, it can intercept SMS messages, block incoming calls, show phishing windows (web fakes) to the user, obtain contacts from the contact list, execute specified USSD requests including redirecting calls to a different number through USSD, receive all incoming/outgoing/draft SMS messages and send them to the server, send SMS messages both to a specified number and to all numbers from the contact list, obtain the list of installed applications, encrypt data on the device (ransomware), intercept keystrokes (keylogger), deploy a SOCKS5 proxy (contained in a separate module), record audio and send it to the server, obtain current location

data (through GPS/mobile network and Wi-Fi), show fake push notifications, launch any app installed on the device, and open URLs in browser.

If the C&C server with the necessary panel version has not been found in the existing list, the client will try to extract a new list of C&C servers through Twitter.

In March 2019, the alleged creator of the bot, maza-in, was arrested. As a result, the user rootHox started selling the source code of Anubis version 2.5 on an underground forum in July 2019.

Threat name	Detection	Regions attacked
FlexNet	2014	Россия

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from a C&C server, the application can do the following:

- change the C&C server address
- send an SMS message to a specified number
- send bulk SMS messages with a specified text
- forward SMS messages to a remote server
- reply to SMS messages and delete them to conceal the fact from the user
- run USSD requests
- schedule commands: configuring a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialogs added to its functionality. They are disguised as popular applications in order to obtain the victim's bank card details. The following fake dialog boxes were detected:
AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threats and malware for PC

Threat name	Detection	Regions attacked	Related notifications

FakeSecurity JS Sniffer	December 2018	Global	CP-2008

FakeSecurity is a bank card sniffer first discovered by Group-IB specialists in December 2018. This family of sniffers was used by one criminal group, which infected websites powered by Magento CMS. The threat actors injected a link to their malicious script into a website's code, which was The script was loaded and then intercepted the payment data of the online store's visitors when they made payments. It then sent these data to the threat actors' server.

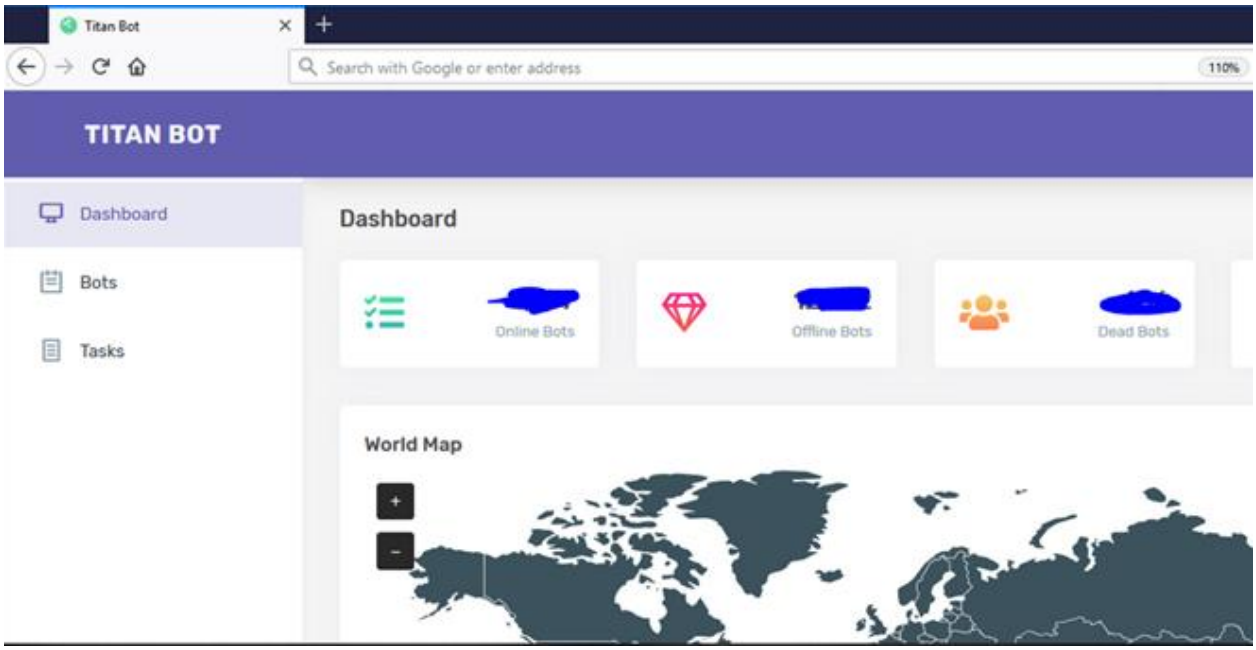
Analysis of three domains used by the FakeSecurity group revealed that some of them had been used in a malware distributing campaign that started in March 2019. The attackers distributed links to webpages where users were asked to install a missing plug-in so that the document would be displayed correctly. If the user started to download the application, their computer was infected with malware for stealing passwords. This attack involved Mephistophilus phishing kits and Vidar password stealer.

Threat name	Detection	Regions attacked	Related notifications
Titan	August 2019	Global	CP-1986

On August 17, 2019, a user nicknamed opoboc posted a link on Exploit.in, an underground forum, to their Github account, where they claimed to have the source code of the Titan banking bot, which they developed themselves.

According to the description on Github, the bot has the following capabilities:

- Keylogger,
- Track 1/2 Grabber
- Backconnect,
- Remote access to the infected machine,
- Reverse SOCKS5
- Form grabber
- Web injects



Titan admin panel.

Threat name	Detection	Regions attacked	Related notifications
CVE-2019-1069 exploit	August 2019	Global	CP-1980

On August 18, 2019, a threat actor nicknamed luxor2008 started selling an LPE exploit for CVE-2019-1069 on an underground forum. Microsoft patched this vulnerability in June 2019. CVE-2019-1069 is an EoP (escalation of privileges) vulnerability in Windows Task Scheduler. All Windows 10 versions as well as Windows Server 2016 and later are vulnerable. It is worth mentioning that luxor2008 is well known in the underground community and has already sold exploits before (for CVE-2018-8453 and CVE-2016-7255). The threat actor is prepared to work through a guarantor, which suggests that they really have what they advertise.

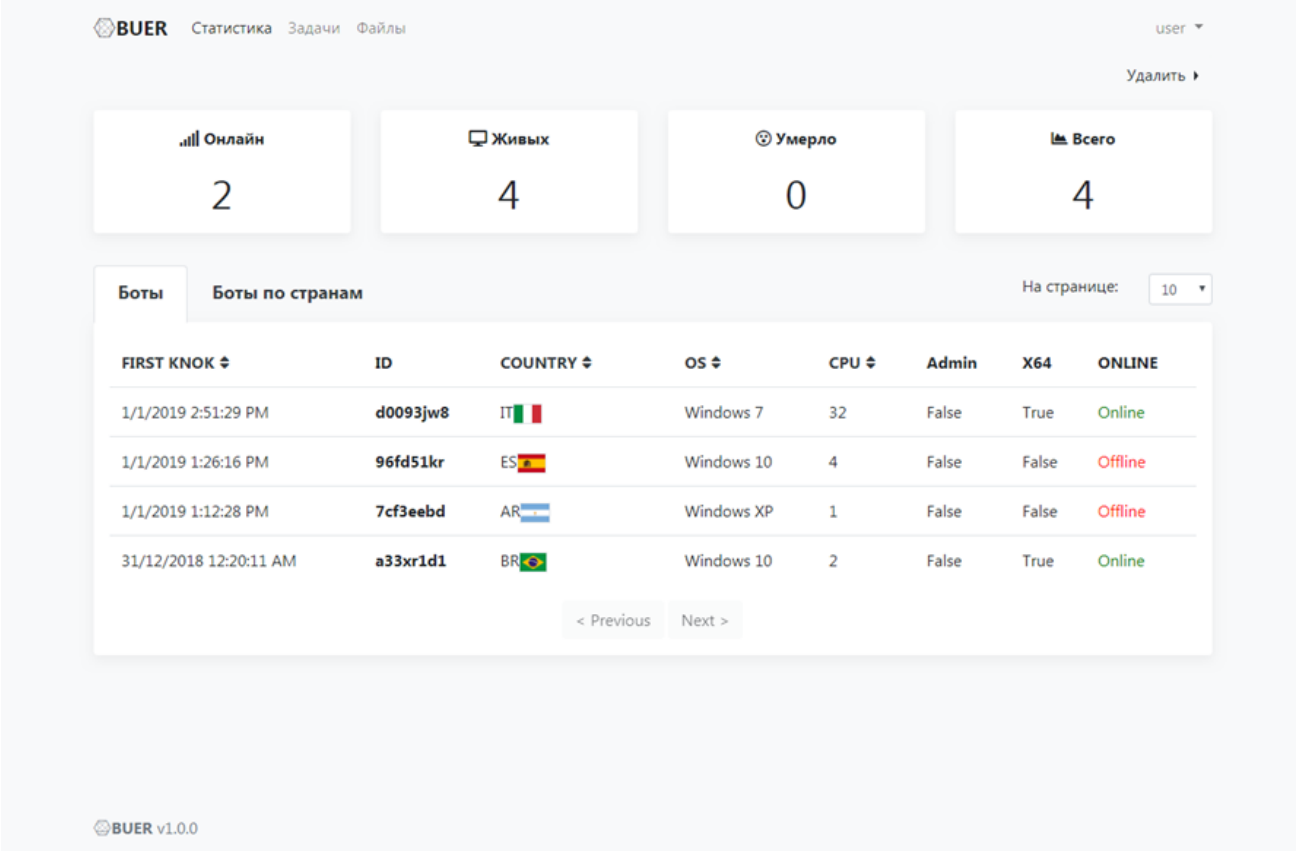
The exploit is sold at US$5,000.

We believe that the buyers of this exploit will be able to use it for targeted attacks.

Threat name	Detection	Regions attacked	Related notifications
Buer Loader	August 2019	Global	CP-1987

On August 15, 2019, a user nicknamed memeos made a post about selling a new loader called Buer loader on exploit.in, an underground forum. The malware works on all operating systems from Windows 7 to Windows 10 (x86/x64) and has a size of between 22 and 26 KB. It is worth mentioning that the Trojan is written in C, has module architecture, and does not work in post-Soviet countries.

The price for the malware is $350.



Buer loader admin panel

Threat name	Detection	Regions attacked
Gootkit	2014	France, Italy, Poland, Austria, Germany, Portugal, US

Gootkit is a banking Trojan that can record video, take screenshots, change web pages using web injects, redirect victims to phishing sites, install a keylogger, and block URLs.

Targets detected in Q3 2019:

Credit Agricole (FR, IT)
ABANCA Corporación Bancaria, S.A.
Sabadell
Oberbank (AT)
Bankaustria
Deutsche Postbank AG
Banque Populaire (FR)
BB&T Bank
Unionbank (US)
Caixa
Santander (DE, PT)
IntesaSanpaolo
Commerzbank
Suntrust
Deutschen Bank
Usbank
Chase Bank
HSBC Bank
Bank of Montreal
bancopopolare.it

unicredit.it
raiffeisen.at
ing.it
popso.it
poste.it
santandertotta.pt (Portugal)
creditoagricola.pt (Portugal)
abanca.pt (Portugal)
credem.it
bancaeuro.it
vkb-bank.at
bnpparibas
millenniumbcp.pt
inbank.it
wsk-bank.at
bancagenerali.it
poste.it
credem.it
banking-oberbank.at

Threat name	Detection	Regions attacked
Trickbot	2016	Australia, Canada, Spain, Germany, US

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed through email spam. Lately, it has often been distributed using Emotet.

Trickbot's new features include the ability to steal PIN codes and data from the accounts of major US mobile operators such as Sprint, T-Mobile, and Verizon Wireless. This was detected in August 2019. In this fraud scheme, the threat actor first gains control over the SIM card and the number of their victim (as a rule, this is done through contacting the mobile operator and employing social engineering techniques, but there are other scenarios too). As a result, the attacker takes control over their victim's phone number and all services it is subscribed to (including bank accounts, email, etc.), as well as onetime passwords, two-factor authentication codes, and so on. Trickbot intercepts traffic for mobile operator login pages and shows victims a modified login page where apart from regular data (phone number and password) the user is asked to enter their PIN code.

Analysis of detected samples showed that in Q3 2019 attacks with Trickbot targeted the following banks:

Toronto-Dominion Bank (TD BANK)
Fifth Third Bank (53 bank)
Santander
Caisses Desjardins
JPMorgan Chase
Citibank
Bank of America
BB&T Bank
Deutschen Bank
Deutsche Postbank AG
Sparda Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Bank of Montreal
The National Bank of Canada
Huntington Bancshares, Inc.
Capital One
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)
Charles Schwab Corporation
Comdirect Bank AG
Commerzbank
Wells Fargo
Bankaustria
Halifax
TD Ameritrade
Sparkasse
Commonwealth Bank of Australia
Regions Financial Corporation
Lloyds Bank
Suntrust

Usbank
Scotiabank
E-Trade
USAA Bank

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Australia, Italy, Germany, Poland, Canada, US

We continue to observe Gozi attacks in Australia and Italy. Interestingly, one of the campaigns where Gozi was distributed through Emotet targeted banks in Germany and Poland, in addition to Italy.

In July 2019, Gozi samples that targeted banks in Canada and the US were detected for the first time.

In Q3 2019 we did not detect any Gozi attacks in Japan.

Targeted banks in Australia:
Westpac
Suncorp
Bankofmelbourne
Banksa
Stgeorge
Commonwealth
Bendigobank
Bankwest
ANZ

Targeted banks in Italy, Germany, and Poland:

ing.de
sparda.de
targobank.de
comdirect.de
consorsbank.de
netbank.de
fidor.de
dkb.de
santander.de
hypovereinsbank.de
norisbank.de
commerzbank.de
deutsche-bank.de
tecmarket.it
cbibanking.it
cim-italia.it
credem.it
fideuramonline.it
bcp.it
mps.it
sella.it
cabel.it
fmbcc.bcc.it
bancapassadore.it
bancobpm.it
finecobank.com
nowbankingcorporate.it
credit-agricole.it
brsspa.it
banking4you.it
nexi.it
ing.it
cariparma.it
bancagenerali.it
poste.it
hellobank.it
gruppocarige.it
chebanca.it
bancaeuro.it
icbpi.it
inbank.it
italy.db.com

bancaprossima.com
qweb.quercia.com
pec.it
vianova.it
ipko.pl
ingbank.pl
centrum24.pl
citibankonline.pl
e25.pl
ideabank.pl
credit-agricole.pl
bosbank24.pl
bnpparibas.pl
ibiznes24.pl
gb24.pl
toyotabank.pl
plusbank24.pl
nestbank.pl
neobank24.pl
popso.it
getinbank.pl
ipkobiznes.pl
pbsbank.pl
mbank.pl
unipolbanca.it
chebanca.net
relaxbanking.it
tim.it
csebo.it
unicredit.it
ubibanca.com
quercia.com
intesasanpaolo.com
bnl.it
cedacri.it

Targeted banks in Canada and the US:
Toronto-Dominion Bank (TD BANK)
Scotiabank
Royalbank
BANQUE NATIONALE DU CANADA
Tangerine
Desjardins
Canadian Imperial Bank of Commerce (CIBC)
Bank of Montreal
Bank of America
Chase
Citi
Scotiabank

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	US, Canada, UK

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and functionality comparable to Zeus, including web injects, data theft, and the ability to inject the code into other processes. One of the bot's specific characteristics is its ability to deploy a proxy server on the infected machine and redirect all internet traffic using that server.

In addition to banks, IcedID has lately attacked e-commerce businesses. In either case, the criminals' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

The detected IcedID samples target banks in the US, Canada, and the UK, as well as e-commerce vendors.

Known targets:

HSBC Bank
JPMorgan Chase
Citibank
Caisses Desjardins
Bank of America
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Chase Bank
Charles Schwab Corporation
Wells Fargo
Fifth Third Bank (53 bank)
Capital One
Post Oak Bank (US)
Scotiabank
Halifax
TSB Bank
Usbank
Unionbank (US)
PNCbank
USAA Bank
Mandtbank

Threat name	Detection	Regions attacked
RTM	2015	Russia

The program is written in Delphi and is a modular Trojan. Judging by its functionality, the Trojan targets remote banking services and payment systems. Its latest tracked sample searched for the following remote banking services on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, and VTB24.

The RTM group has a main panel and a separate Proxy panel showing banks they target specifically: all requests are sent to phishing servers where the traffic is proxied.

Since early 2019, mass emails that distribute the RTM Trojan have continued to be actively sent out. We detect such emails almost every day. The recipients are Russian-speaking legal entities.

Threat name	Detection	Regions attacked
Danabot	2018	Austria, US, Poland

The modular banking Trojan Danabot was first detected in the spring of 2018. It uses web injects and intercepts the victim's data. It has VNC, Sniffer, Stealer, TOR and RDPWrap modules.

New features were later added to it, namely, several layers of encryption for transferring data to the C&C server and a new loader component with an ability to load plugins along with the main module, which makes it an even greater threat.

In Q3 2019, detected Danabot samples mostly banks in Australia, the US, and Poland:

Fifth Third Bank (53 bank)
Australia and New Zealand Banking Group
Westpac
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Commonwealth Bank of Australia
National Australia Bank
Usbank
Wells Fargo

toyotabank.pl
bosbank24.pl
centrum24.pl
citibankonline.pl
credit-agricole.pl
e-skok.pl
e25.pl
db-pbc.pl
ibiznes24.pl
ipko.pl
gb24.pl
bnpparibas.pl
ingbank.pl
nestbank.pl
citidirect.com
neobank24.pl
getinbank.pl
ideabank.pl
sgb.pl
aliorbank
t-mobilebankowe.pl

Threat name	Detection	Regions attacked
Ramnit	2010	US, Japan

The Ramnit banking Trojan was first discovered in 2010. In 2015, the Ramnit botnet was taken down by a joint international operation coordinated by Europol. The Trojan's activity, however, did not stop and it continued to be used to compromise bank cards in North America and Europe up until the beginning of 2018. It was followed by a lull, but in Q3 2018, Ramnit resumed its activity. The threat actors focused on attacks against Japan and the US, occasionally targeting European banks.

In June 2019, a threat actor with the nickname m0roz started selling the source code of this malware on an underground forum. According to their post, it is being sold only to one person. As at September 2019, it is unclear whether a copy of the malware has been sold: the seller is not replying to questions, but the forum topic has not been closed.

Known Ramnit targets:
Credit Saison
Idemitsu Credit Co.
Mitsubishi UFJ NICOS Co
Aeon Bank
Life Card Co.
Pocket Card Co.
Cedyna Financial Corporation
Epos Card Co.
Rakuten
Sumimoto Mitsui Card Co.

Attacks on ATMs and POS terminals

Threat name	Detection	Regions attacked
Badhatch	July 2019	Europe

FIN8 upgraded their tool for attacks on POS terminals by adding new features. Launching Badhatch leads to successive downloads of PowerShell scripts with shellcode. The first-stage script copies its code into the existing PowerShell process and then loads a DLL (designed to communicate with the C&C server) into the same memory space. Next, the malware implements an asynchronous TLS-wrapped TCP/IP channel and delivers additional modules.

One of the downloaded components, called PoSlurp, is designed to retrieve 15- or 16-digit bank card numbers. The module does not run the Luhn algorithm on card numbers it collects, instead it sends unprocessed data to the threat actors. Unlike previously studies samples, this version of the scraper is a PowerShell script designed for 64-bit architecture. The malware does not use low-level API functions and directly calls operating system commands to place its components in memory.

Even though Badhatch uses a number of new methods to effectively run in the memory of target POS terminals, it does not have built-in sandbox detection tools.

Threat name	Detection	Regions attacked	Related notifications
MagicPOS	July 2019	Global	CP-1992

On August 18, 2019, two copies of the source code of MagicPOS, a malicious program for POS terminals, were put up for sale on Exploit, an underground forum. The author of the post is a user named cartonash. Together with the source code, the seller provides a script for creating card shops. However, in a conversation with the author Group-IB found out that cartonash was not the developer of the malware and that they had earlier bought it from the developer.

In late May 2019, Group-IB specialists discovered and analyzed a MagicPOS campaign that mainly targeted Brazil and France.

Threat name	Detection	Regions attacked
Emporium Rodrigues store compromise	July 2019	Brazil

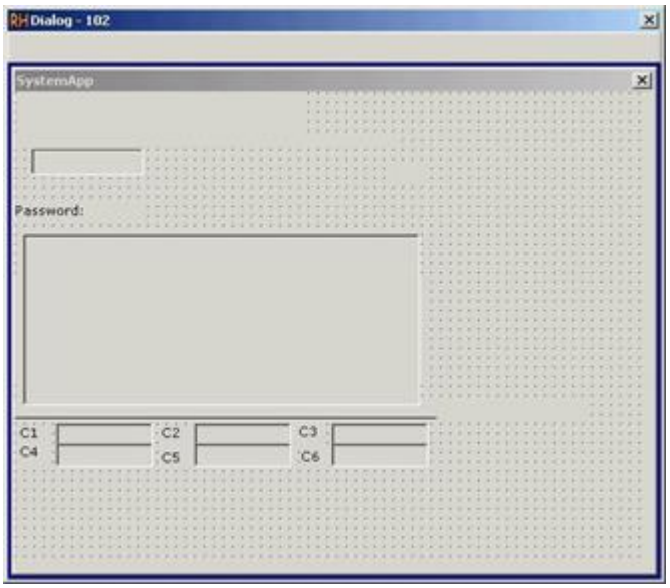
Group-IB specialists' analysis of underground forums revealed that a threat actor has access to all POS terminals of Emporium Rodrigues, a Brazilian supermarket chain. This poses a risk of the company being

infected with a POS Trojan that could compromise bank cards. The threat actor is selling the access they gained.

Threat name	Detection	Regions attacked	Related notifications
NCRApp.exe	April 2019	Global	CP-1975

In April 2019, ATM malware was detected in African countries. Group-IB specialists conducted an analysis and established that the malware is designed for withdrawing banknotes from NCR ATMs. In certain situations it can function on any other hardware that supports the XFS standard.

The malware is designed to control ATM dispensers through the PIN pad. If the user enters a certain PIN, which is specified in the malicious code, the malware lets them interact with the dispenser directly. If the attacker inserts a card with a certain number (it is also specified in the code), the dispenser will issue all banknotes it contains.



Dialog box of the application.

As for compromised organizations, attacks on POS terminals in Q3 2019 took place in the following companies:

- Hy-Vee, a chain of US supermarkets. More than 5.3 million cards compromised through the chain were put up for sale on underground web resources. The chain includes shops, gas stations, and restaurants (Hy-Vee Market Grilles, Market Grille Expresses, and Wahlburgers).
- Russel Stover's Chocolates, a US candymaker, announced that there had been a breach of bank card data at its stores that took place between February 7 and August 9, 2019. As a result, 74,000 compromised cards appeared on an underground card shop.

The attacks were reported in August 2019.

Threat name	Detection	Regions attacked
ATMDtrack	September 2019	India

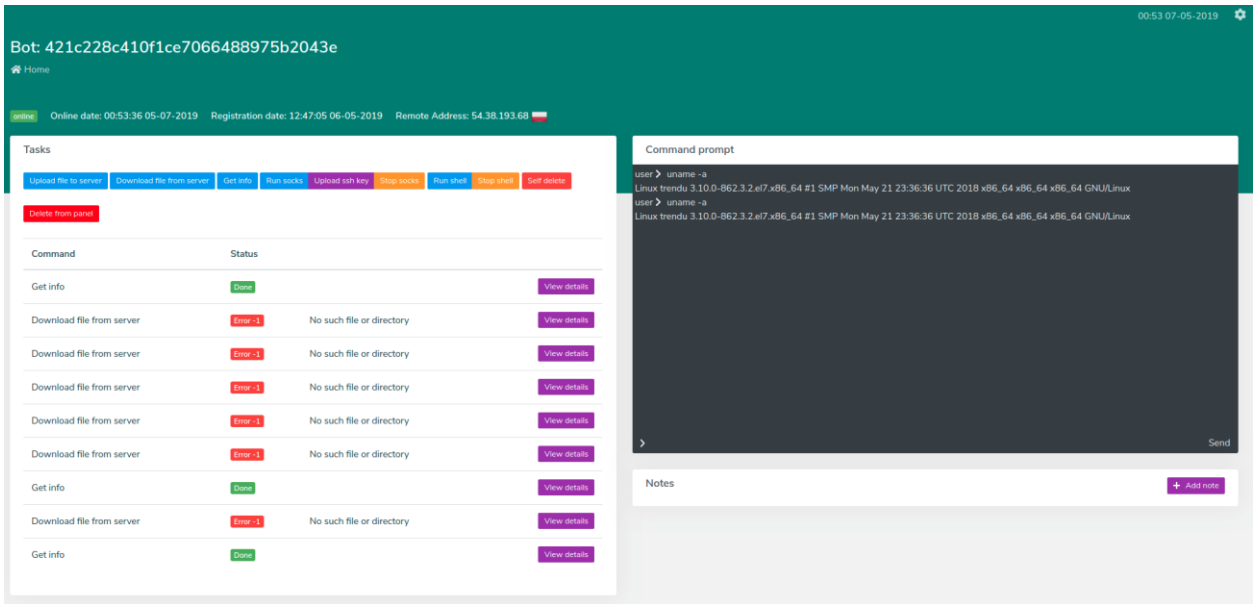
In September 2019, it was revealed that Lazarus may have been behind the ATMDtrack malware. It was established that ATMDtrack was used in the late summer of 2018 against Indian financial organizations. The threat actors incorporated the Trojan into ATMs, where it recorded information about inserted cards and saved it on the attackers' resources.

As at late September 2019, there have been no detailed analyses of this malware and it is yet to be established whether it is something unique or a previously used tool under a new name.

Malware for Linux

Threat name	Detection	Regions attacked	Related notifications
LsBot	June 2019	Global	CP-1938

The source code of a new Linux bot called Lsbot was put up for sale on Exploit, an underground forum. The malware is designed for targeted attacks; it can work with unprivileged user rights, connect to the C&C server via SOCKS5 backconnect or DNS protocol, and non-interactively execute Linux commands on infected devices. The bot supports various Linux distributions (Red Hat, CentOS, Ubuntu, etc.).



LsBot admin panel

State-sponsored APTs

APT name	Regions attacked	Operation start
APT10	Asia, Europe, Africa, Middle East	2012

In late June 2019, there was information about a campaign called Soft Cell, which started in 2012 and affected at least ten telecommunications operators in Asia, Europe, Africa, and the Middle East. APT10 is believed to be behind the attack. The threat actors gained access to their victims' networks and stole their data.

The attack started with deploying a modified version of the China Chopper web shell on a vulnerable server. The threat actors carried out a series of reconnaissance activities to obtain information about the victim. They then attempted to dump credentials stored on the compromised machines in several ways: they used a modified version of Mimikatz and applied the pass-the-hash technique to the hashes they obtained; they also dumped specific hives from the Windows Registry.

The hackers managed to compromise a number of servers and gain full access to the domain controller. They relied on WMI and PsExec to move laterally and install their tools. The group also additionally deployed the PoisonIvy RAT using a DLL side-loading technique, and PlugX. After that, the hackers deployed two other custom-built web shells, from which they launched reconnaissance commands, stole data, and dropped additional tools.

The threat actor exfiltrated data using web shells and hTran. The compromised data were compressed into a password-protected archive using winrar.

APT10 is a Chinese cybercriminal group, which has been active since at least December 2009. Some researchers say the group has been active since 2006. The threat actor carries out attacks to primarily spy on construction, engineering, aerospace, telecommunications, and government organizations. Japanese organizations have been affected the most.

APT name	Regions attacked	Operation start
Turla	Global	September 2018

In July 2019, it was reported about the Turla group's new tools that they used in attacks on government organizations. The group's arsenal now includes the Topinambour dropper, which is used for distributing the well-known KopiLuwak backdoor and its earlier analogues: the .NET RocketMan Trojan and the PowerShell MiamiBeach Trojan.

To deliver this to targets, the operators use legitimate software installers infected with the Topinambour dropper (Softether VPN 4.12, psiphon3, Microsoft Office activators). It contains a tiny .NET shell that will wait for Windows shell commands from the operators. The campaign operators use SMB shares on rented private servers (VPS) to spread the next-stage modules using just **net use** and **copy** Windows shell commands.

The next stage involves the deployment of KopiLuwak. First, the dropper is loaded, which can create tasks in Task Scheduler, collect information about the victim machine, and drop next JavaScript. The dropped java script decrypts one more script through a Task Scheduler task and runs the decrypted code. This final-stage code is able to parse and execute custom commands from the C&C server. The malware communicates with a legitimate compromised WordPress-based website and gets the commands exit,

upld, **inst**, **wait**, and **dwld**. The downloaded script takes an executable from the Windows registry and runs it.

Along with KopiLuwak, the threat actor used the .NET RocketMan Trojan, which can execute the following commands: **#down/#upload** — make an HTTP POST request to download the file to the victim's computer/upload the file to the server; **#timeout** — wait for a specified amount of time; **#stop** — stop the Trojan; **#sync** — send the encrypted string "RocketMan!" to the server.

Another of the new tools is the PowerShell MiamiBeach Trojan. It has the same functionality as RocketMan and can additionally execute the **#screen** command for taking screenshots.

Turla (also known as Snake, Uroburos, Venomous Bear, and KRYPTON) is a Russian-speaking cybercriminal group believed to be active since 2007. The main aim of Turla's attacks is stealing information from diplomatic, government, military, educational, research and pharmaceutical organizations.

APT name	Regions attacked	Operation start
DarkHotel	China	May 2019

In June 2019, a campaign by the DarkHotel group was detected. It targeted the leaders of Chinese foreign trade organizations. The threat actor may have used the watering hole technique to distribute a legitimate program called Netease Mailbox Master (start.exe) with malware within.

First, the "start.exe" file is launched, and if its installation is successful, a request is sent to the C&C server to get a .dll file. It is downloaded using either PowerShell or "rundll.exe." The downloaded file is a RAT that can download additional plugins, such as keylogger, database stealer, screenshotter. To drop the .dll the threat actors modify the registry and also uses CMSTP to bypass UAC.

DarkHotel is a cybercriminal group, which has been active since 2007. It is believed to be based in North Korea. Its primary targets are luxury hotel guests and political organizations mostly in North-East Asia. The attacks aim to collect confidential information and carry out cyberespionage.

APT name	Regions attacked	Operation start
APT28	Ukraine	August 2019

On August 20, 2019, there was a phishing email campaign attributed to APT28. The detected email contained a malicious .docx file and was sent to the Ministry of Foreign Affairs of Ukraine. Opening the file downloaded malicious templates hosted on Dropbox. After a series of actions, a chunk of encoded data is extracted and transformed into two files: .doc and .exe. The executable and is a variant of the Zebrocy loader (which is written in Nim) and is launched when the .doc is opened.

Its main task is to download additional malicious components after collecting system information. The specialists were not able to obtain the final payload, but considering that APT28 usually downloads credential compromise tools, keyloggers, and remote access malware, it is likely that they used similar tools in this case.

APT28 (also known as Fancy Bear, Sednit group, Sofacy, Pawn Storm, Strontium, Tsar Team, TG-4127, Group-4127, TAG_0700, Swallowtail, Iron Twilight, and Group 74) has been active since 2004. Its members are Russian speakers. Most of their attacks have targeted political and military organizations, and, to a lesser extent, media outlets and sports organizations.

APT name	Regions attacked	Operation start
Attack involving IoT devices	Global	April 2019

In April 2019, Microsoft experts observed attacks on customers' corporate networks. The attacks involved the compromise of IoT devices. The researchers attribute the attack to APT28 and say that because the compromise was stopped at early stages, the end goal of the group is unclear. We believe that BlackEnergy might be behind the attack, because the way it was carried out is most similar to this group's activity.

The hackers first compromised a VOIP phone, an office printer, and a video decoder to gain initial access to the corporate networks. In two of the cases, the passwords for the devices were deployed without changing the default manufacturer's passwords and in the third instance the latest security update had not been applied to the device. Once the actor had successfully hacked the IoT devices, a simple network scan to look for other insecure devices allowed them to discover and move across the network in search of higher-privileged accounts that would grant access to higher-value data. The actor ran tcpdump to sniff network traffic on local subnets.

BlackEnergy (also known as SandWorm, Quedagh, TeleBots, and GreyEnergy) is a cybercriminal group active since at least 2010. The group's activities suggest that it is particularly interested in attacks on critical infrastructure. In 2017 and 2018, the group added BadRabbit and VPNFilter to their arsenal. The latter program is designed for attacks on routers and contains a module for detecting SCADA systems.

APT name	Regions attacked	Operation start
APT34	Middle East	June 2019

In late June 2019, a new phishing campaign by APT34 was observed. The group masqueraded as a member of Cambridge University and used new malicious programs. Some of them are PowerShell-based, while others are written in Golang. The phishing campaign targeted oil and gas, energy, utilities, and government industries.

On June 19, 2019, a file called System.doc was discovered, which despite its .doc extension is a PE file (Windows Portable Executable). The file was identified as TONEDEAF, which is a backdoor that communicates with the C&C server using HTTP requests. It supports collecting system information, uploading and downloading of files, and execute arbitrary shell commands.

The file was dropped by an Excel document called ERFT-Details.xls, which had been downloaded through a link on Linkedin. Opening the .xls document creates a scheduled task named "windows update check" that runs the dropped backdoor. The backdoor then connects to the C&C server offlineearthquake[.]com.

Several payloads tracked as VALUEVAULT, LONGWATCH, and PICKPOCKET were discovered on that C&C server.

Group-IB specialists identified how the C&C registration scheme was organized, which helped identify additional C&C servers and a potential victim.

OilRig (also known as APT34) has been active since late 2015. The group is based in Iran and is believed to be linked to the Iranian government. The actor mainly targets the banking sector, airlines, educational institutions, government entities, and IT and telecommunications companies. The group's targets are based in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, the US, the UAE and Lebanon.

APT name	Regions attacked	Operation start
OceanLotus	Vietnam, Cambodia	July 2019

In early July 2019, a report on a previously unknown Trojan called Ratsnif by the OceanLotus group was published. A total of four samples were was discovered. Three of them were developed in 2016, while the fourth one was created in the second half of 2018.

The earliest one was created on August 5, 2016, on the same day as its C&C server. The next sample was compiled a day later. It contains only one minor difference in functionality, whereby a call to **pcap_dump_flush()** has been removed. Both samples were submitted to VirusTotal within a minute of being compiled and contain the same path as the PDB information. Given that the files were uploaded through the API, it seems likely that this sample was submitted automatically. The next sample was compiled in September 2016.

The above-mentioned samples have the following features:

- C&C over HTTP
- Packet sniffing
- ARP poisoning
- DNS spoofing
- HTTP redirection
- Remote shell

The fourth sample was compiled on August 8, 2018 and is delivered through a bespoke OceanLotus shellcode.

For this particular sample, the actual executable is Base64-encoded within a loader DLL and wrapped in two layers of shellcode. The loader DLL decodes the payload, copies it to memory and executes the first-stage shellcode, which will decompress the binary and execute the second-stage shellcode. The second-stage shellcode will inject the executable into memory and hook several API functions responsible for returning the process command line.

Unlike the 2016 variants of Ratsnif, this variant employs multiple sniffers for harvesting sensitive information. This will minimize the amount of data the attacker has to collect, exfiltrate and process, and also reveals what information the attacker is interested in.

All of the samples have search[.]webstie[.]net as their C&C servers. However, the September 2016 sample has one more server: dns[.]domain-resolve[.]org.

In late July 2019, OceanLotus used Quasar, an open-source RAT. The sample is called "ប្រកាស តែងតាំង មុខតំណែង _docx.exe," which translates as "Appointment of government officials." Cambodian government agencies are believed to have been the targets in this attack.

The discovered sample is an SFX archive created in February 2019 and first uploaded to VirusTotal on July 22, 2019. When run, the SFX archive executes a series of commands, which it uses to add records to the registry, launch a module that calls the RAT through "regsvr32.exe," and open a Word document to conceal its activity.

On August 7, 2019, malicious samples that employed a DLL side-loading technique started to be uploaded to VirusTotal. One of the samples, which has Vietnamese origins and is called "Danh sach cac ca nhan to chuc tai Hai ngoai va quoc noi ung ho cac tu nhan luong tam bi buc hai.exe" (which is a legitimate app, WinWord.exe) is delivered in an archive together with "wwlib.dll," a malicious library.

Starting the executable launches the process of connecting to the C&C server. Persistence in the system is ensured through executing the file "word.bat," which schedules a task called "Googlephotosyn" to launch "Googleupdate.exe." The file is a legitimate Google application, which when launched loads "goopdate.dll," a malicious library located in the same directory. Based on the C&C server that the sample communicates with, it was possible to detect several more samples that use identical techniques and files to ensure persistence in the system. All of them target Vietnam.

OceanLotus, also known as APT32/APT-C-00/SeaLotus/Sinh Tử Lệnh/Cobalt Kitty, has been active since late 2009 and is believed to be based in Vietnam. The group attacked Vietnamese bloggers and dissidents and launched targeted attacks on industrial and government entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the US. Apart from phishing emails, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start
Dragonfly	UK	2017

In late July 2019, information was published about attacks carried out by Dragonfly in 2017. The report described an updated version of Karagany and a previously unknown RAT called MCMD. MCMD is a reverse command shell, which can execute arbitrary commands on the device, as well as download and upload files. To establish communication between the RAT and C&C server, the threat actor uses PHP pages on compromised websites.

Unlike the 2017 samples, which installed the malware in the same directory the dropper was launched from, the updated Karagany version were hardcoded to install to a specific path. A number of other files are created in the installation directory, but they remain empty: "up_stat.txt," "stat_ag.txt," "serv_stat.txt," and "proxy.txt."

Additional plugins downloaded by the malware are dropped into the SearchIndexer directory with the names "svchost<[0-9]+>.txt." Interestingly, the downloaded plugins are only executed once. Even if the same plugin is executed multiple times, it will be re-downloaded per execution. Kargany does not delete used plugins.

Communication with the C&C also changed. There is now a hard-coded User-Agent string. The malware is hard-coded with specific URI patterns to communicate with the C&C server via HTTP POST requests. Traffic is encrypted by SSL/TLS. Before being transmitted to the C&C server, the data are encoded using the AES-128-CBC algorithm and a pseudo-randomly generated initialization vector (IV). Once the data have been AES-encrypted, it is prepended with the IV value and Base64-encoded for transmission. Some cases involved a file called "ngate.txt," which contained RC4-encrypted C&C IP addresses. The RC4 decryption key for this file is hard-coded in the Karagany malware and was the same across all observed samples.

Many of the plugins deployed by Karagany have similarities to tools used by the TeamSpy group. Some sources say that TeamSpy was last active in 2013 and may have been operated by a Russian intelligence service.

It was also established that there was a Kargany infection on 21 March 2017 after a visit to adobe.com. Interestingly, the size of the downloaded file called "install_flash_player.exe," was initially 21027424 bytes, and changed to 20647512 after being unpacked. This change in size suggests that the dropper deletes its presence in the system and leaves only the legitimate Adobe Flash loader. Researchers believe that the dropper got into the system through a compromised router located between the user and the

legitimate website Adobe.com. In one of our previous reports, we wrote that this group had used a compromised Cisco router to collect account data during a phishing campaign in the UK.

Less than 24 hours passed between the time the dropper appeared in the infected network and the first interactive session. Interestingly, the time of the first interactive session was 08:58:31 (Moscow time, GMT+3), which coincides with the beginning of the working day in Russia.

The group has been active since 2010. Considering what it is focused on, the time when it is active, and its resources, researchers converge that the group is based in Russia and is linked to the Russian government. Most of its attacks target the energy sector, pharmaceutical, aviation, nuclear, educational and military organizations, and water supply systems. Its main targets are in the US, Spain, Turkey, Canada, Poland, Switzerland, the UK, and others. The threat actor have used three methods of infecting systems: spear-phishing, installers with Trojans, and watering hole attacks.

APT name	Regions attacked	Operation start
MuddyWater	Iran, Tajikistan, Uzbekistan	June 2019

On June 27, 2019, a decoy document called “letter.doc” was uploaded to VirusTotal. The document contains malicious macros, which when enabled drop a .bat file and PowerShell files. Closing the document, triggers the .bat file, which restarts the operating system. This is done to run the PowerShell script, which is placed in the startup folder by editing the registry. The contents of the PowerShell script are Base54-encoded. After it was decoded, it was possible to establish that it connects to the C&C server to download the file “p.txt” from a remote node. This file contains obfuscated PowerShell code, where two additional IP addresses are specified.

Interestingly, the macros in that document are called H3AirStrike, referring to the H-3 airstrike. The names of variables in the macros also mention fighter aircraft names. The body of the document resembles an attack on the oil and gas industry in Nigeria.

A month later, on July 31, 2019, a decoy document called “CV-Meryem-EN.doc” was uploaded to VirusTotal. The sample is disguised as a CV and enabling the macros in it triggers communication with the C&C server. Interestingly, the document was available for download on the official website of the Academy of Sciences of Uzbekistan, which had apparently been hacked. The contents of the CV pointed to its Uzbek origins.

A document called “NeedDedicatedServer.xls” was uploaded to VirusTotal on September 6, 2019. When the macros it contains are enabled, the document makes a request for a file hosted on a compromised web server. The request involves sending information about the infected system to the C&C server. The malicious macro adds a new registry entry called AppDataztfjmwhn to autorun a dropped VBS file.

The document’s metadata mention its creation date: 2019-06-22 12:23:57. A total of 12 malicious files with the same date were uploaded to VirusTotal. Five of the detected files are .xls documents with malicious macros and were submitted to VirusTotal between July 9, 2019 and September 8, 2019.

One of them is “Azim.Tarabar.xls,” which when the macros are enables makes an identical request to a compromised server. Azim Tarabar is an Iranian logistics company. At the time of the analysis, three compromised servers had been detected, all of them WordPress-based.

MuddyWater is a cybercriminal group active since 2017 mostly in the Middle East. The group uses its own PowerShell-based backdoor called POWERSTATS. The group’s main activity is cyberespionage in pursuit of Iran’s interests. The threat actor’s targets are: government agencies and organizations, military entities,

and petrochemical and telecommunications companies. The targets are located in Saudi Arabia, Egypt, Tunisia, Turkey, Tajikistan, Iran, Belarus, Russia, Uzbekistan, Georgia, and Pakistan. Most of the victims are located in the Middle East.

APT name	Regions attacked	Operation start
APT33	US, Saudi Arabia, South Korea	December 2016

In early July 2019, in response to the tense military and political situation between the US and Iran, the US Cyber Command uploaded samples of the APT33 group's malware to VirusTotal. The samples are related to the group's activity in 2016-17.

The uploaded samples were first discovered in December 2016 and January 2017. One of them was distributed disguised as fake Flash Player and Google Chrome installers, while another one was masqueraded as Citrix. The campaign targeted government financial, engineering, technical, and healthcare organizations in Saudi Arabia, as well as one British labor-related government agency.

Most infections were carried out by compromising public government servers, but traces of infection through phishing emails with malicious attachments were also detected.

Launching the malicious attachments and fake installers installed the Pupy backdoor.

APT33 is a cybercriminal group active since at least 2012. The group targets organizations in different industries in the US, Saudi Arabia, and South Korea. It is particularly interested in the aviation and energy sectors, which are closely connected with petrochemical production. The threat actor is thought to be linked to the Iranian government and the Nasr institute, which has in turn been linked to the Iranian Cyber Army.

APT name	Regions attacked	Operation start
APT15	Global	2015

ESET specialists discovered a modified version of the Okrum backdoor, which is attributed to APT15.

Okrum was first discovered in December 2016. Throughout 2017 the backdoor was used for targeted attacks on diplomatic missions and government agencies in Slovakia, Belgium, Brazil, Chile, and Guatemala.

Along with Okrum, the group used the BS2005 and Ketrican backdoors, as well as RoyalDNS malware.

Despite Okrum's simplicity, the threat actors are able to conceal its presence. For instance, the loader of the malware is hidden in a .png file, and the user cannot see additional encrypted files. The operators of the backdoor also hide malicious traffic using their C&C server.

Okrum only supports basic commands to download and upload files, execute binaries, or run shell commands. The backdoor can also update itself to a newer version and can adjust the time it sleeps after each backdoor command. Okrum can impersonate a logged-on user's security context using a call to the ImpersonateLoggedOnUser API, in order to gain administrator privileges. It automatically collects the

following information about the infected computer: computer name, user name, host IP address, primary DNS suffix value, OS version, build number, and architecture.

APT15 (also known as Ke3chang, Mirage, Vixen Panda GREF, and Playful Dragon) is a cybercriminal group believed to be based in China. The threat actor has been active since at least 2010. Their aim is cyberespionage against diplomatic organizations in Europe.

APT name	Regions attacked	Operation start
Targeted DNS hijacking campaign	Global	January 2017

Several months into Sea Turtle, a DNS hijacking campaign, the threat actor is not slowing down.

Experts discovered a new DNS hijacking technique. As before, the ultimate target domain's name server records are modified to direct legitimate users to an actor-controlled server. In this case the actor-controlled name server and the hijacked hostnames would both resolve to the same IP address for a short period of time, typically less than 24 hours. In both discovered cases, one of the hijacked hostnames would reference an email service to allow the hackers to harvest user credentials. One aspect of this method that makes it extremely difficult to track is that the actor-controlled name servers were not used for any other purposes, which means that each object hijacked through this method had its own separate name server hostname and IP address.

In one example, a private organization mainly used a third-party service for their authoritative name server. Then, in January 2018, for three hours the organization had its name server records changed to point to a lookalike name server hostname that mimicked a slightly different version of the organization's name. For the same three-hour period, the actor-controlled IP address hosted three hostnames: the two actor-controlled name servers and the webmail hostname. During this period, the threat actor was able to perform a man-in-the-middle (MitM) attack and harvest credentials. The same process was also observed against government organizations in the Middle East and North Africa.

APT name	Regions attacked	Operation start
Gorgon Group	Global	February 2018

Pakistani hackers from Gorgon Group continue to attack government organizations worldwide and have added international foreign trade companies to the list of their targets.

The latest detected sample is a Microsoft document named “Microsoft_activity_report.xls.”

When the document is opened with a table editor other than Office, such as WPS, Hancom, etc., a picture will be displayed prompting the user to open the document using a different version of Excel.

The analysis revealed that the threat actors continue to use Blogspot to conceal their malicious payload and run the code through “mshta.exe,” but this time the payload is obtained by successively accessing Pastebin three times.

As a result, RevengeRAT is downloaded to the victim’s computer. The malware gives the threat actors remote access to the infected systems and allows them to manage files, processes, services, and the Windows Registry, as well as track the victim’s IP addresses, log keystrokes, reset passwords, and even use the device’s web camera.

Gorgon Group was first reported on in 2017, when they targeted government organizations in the UK, Spain, Russia, and the US.

APT name	Regions attacked	Operation start
TA428	East Asia	March 2019

In March 2019, information security experts detected a targeted campaign that utilized malicious RTF documents to deliver custom malware to unsuspecting victims. The campaign was dubbed Operation LagTime IT.

The attack targeted a number of government agencies in East Asia overseeing government information technology, domestic affairs, foreign affairs, economic development, and political processes. The infection vector observed in this campaign was spear phishing, with emails originating from both free email accounts and compromised user accounts. The attackers relied on Microsoft Equation Editor vulnerability CVE-2018-0798 to deliver malware that was dubbed Cotx RAT.

The malware is written in C++ using object-oriented programming. It utilizes wolfSSL for TLS encrypted communication. The initial beacon contains "|"-delimited system information. The data included in the beacon are Zlib-compressed and encrypted with AES-192 in CBC mode utilizing the same keys as the configuration.

The malware then receives AES-encrypted commands from the C&C server, which include working with files, making screenshots, obtaining the list of installed software, updating configuration, and uninstalling itself from the system.

In addition, this APT group uses Poison Ivy payloads, whose C&C infrastructure overlaps with recently identified Cotx campaigns. Based on infrastructure overlaps, post-exploitation techniques, and historic TTPs utilized in this operation, the analysts attribute this activity to the Chinese APT group tracked as TA428.

APT name	Regions attacked	Operation start
HEXANE	Central Asia, Africa, Middle East	April 2018

New threat actors appeared in attacks on industrial enterprises. The actors started their activity in mid-2018 and has been using malicious documents to penetrate networks. The group was dubbed HEXANE (later acquiring a second name LYCEUM). It focuses on the Middle East, Central Asia, and Africa.

HEXANE also targets telecommunications companies, but only as a stepping stone in supply chain attacks. The group's aim is to reach ICS organizations that use the services of these telecom companies.

HEXANE relies on password spraying and brute-force attacks to compromise accounts of targeted organizations. Once the threat actors compromise an account, they start sending spear-phishing emails from this account within the company attaching malicious Excel files to the emails.

Once a user clicks on the attached Excel file, their PC will be infected with a Trojan called Danbot, which can transfer and receive data over DNS and HTTP protocols, download and upload files, and execute commands via cmd.exe.

At the moment, the specialists do not go so far as to state what country HEXANE is from, but similarities with groups such as OilRig (Iran) and APT33 (Iran) have been observed.

APT name	Regions attacked	Operation start
Gamaredon Group	Ukraine	April 2019

Cybersecurity experts discovered new spyware, which is designed to compromise Linux users' data. It was dubbed EvilGnome and seems to be at the development and testing stage, since the detected samples had unfinished keylogger functionality and metadata that typically do not appear in production versions.

EvilGnome is disguised as a legitimate GNOME extension that allows Linux users to extend their desktop functionality. EvilGnome is distributed as a self-extracting archive shell script created with makeself, a small shell script that generates a self-extractable compressed .tar archive from a directory.

EvilGnome contains five modules called Shooters:

- ShooterSound — Uses PulseAudio to captures audio from the user's microphone.
- ShooterImage — Uses the Cairo open source library to take screenshots of the user's desktop.
- ShooterFile — Uses a filter list to scan the file system for newly created files.
- ShooterPing — Receives new commands from the C&C server, such as downloading and executing new files, setting new filters, etc.
- ShooterKey — Can be used for keylogging, but is not used yet. The module is most likely in development.

The techniques and modules employed by EvilGnome, namely the use of SFX, persistence with task scheduler, the deployment of information stealing tools, and the use of the same IP address, resemble those of Gamaredon Group, which is believed to be behind EvilGnome.

Gamaredon Group is a Russian threat group. It has been active since at least 2013. At first the group borrowed tools for their attacks, but then started using their own malware. Their attacks target governments and law enforcement and government organizations mostly in Ukraine.

APT name	Regions attacked	Operation start
Kimsuky	South Korea, France, US, UK	July 2019

The Kimsuky hacker group did not slow down and launched a campaign targeting retired South Korean diplomats and government and military officials. The attacks were carried out between mid-July and mid-August 2019. They targeted government officials' Gmail and Naver accounts. The threat actors sent out malicious emails that redirected the victims to fake authorization webpages. The stolen data were then used either to access the victims' accounts and collect information about the organization or attack the current government. Cybersecurity specialists note that retired government officials stay in contact with the incumbent government and often act as advisers.

In addition, in August 2019 experts discovered a webpage imitating the online portal of the Ministry of Europe and Foreign Affairs of France (MEAE). Further analysis of the threat actors' infrastructure uncovered a broader phishing campaign targeting ministries of foreign affairs in three countries, as well as research-oriented organizations, including Stanford University, the Royal United Services Institute

(RUSI), a United Kingdom-based think tank, Congressional Research Service (CRS), a United States-based think tank; and five email providers.

Infrastructure anlaysis revealed similarities with Kimsuky activities.

Kimsuky (also known as Velvet Chollima and Thallium) is a hacker group believed to be based in North Korea. The group has been active in attacking entities on the South Korean territory since 2010, but has lately been expanding the geography of its attacks.

APT name	Regions attacked	Operation start
APT41	Global, США	2012

In August 2019, FireEye released a report in which they described the groups Winnti and BARIUM as one group called APT41.

The group has established and maintained strategic access to organizations in the healthcare, high-tech, and telecommunications sectors. APT41 operations against higher education institutions, travel services, and news/media firms provide some indication that the group also tracks individuals and conducts surveillance.

Group-IB specialists observed that the group's financially motivated activity started in 2012 with the video game industry. The threat actors have extensive experience in compromising corporate networks, including Windows and Linux, until they gain access to game production environments, where they steal source code and digital certificates that they later use to sign malware with.

APT41 utilizes their access to production environments to incorporate their malicious code into legitimate files, which are then spread among victim organizations. This supply chain tactic is also characteristic of the most famous and recent espionage campaigns by APT41.

APT41 employs an arsenal of more than 46 different malware families and tools, including publicly available utilities, malicious programs borrowed from other Chinese espionage groups, and tools that are you unique to this group.

In addition, in April 2019 experts detected suspicious activity on a publicly-accessible web server at a US-based research university. The attackers exploited CVE-2019-3396, a vulnerability in Atlassian Confluence Server, and installed a variant of the HIGHNOON backdoor, which consists of multiple components, including a loader, a dynamic-link library (DLL), and a rootkit.

APT name	Regions attacked	Operation start
APT37	South Korea	October 2018

On July 2, 2019, APT37 attackers attempted a phishing attack passing off as a Korean research center and sent a malicious document compressed in an email.

The compressed file included three HWP documents, and one document performs malicious functions.

The malicious document contains BIN0002.ps malicious postscript and obfuscated code. Decoding the encoded data results in a plain text postscript encrypted with the XOR 0xA4 key. The encrypted area

checks for a specific byte through the shellcode function and injects malicious code into the normal process. The malicious code communicates with the C&C server via Dropbox.

There was another wave of attacks by APT37 that targeted North Korean refugee support areas. Characteristic of these attacks is their targeting of both Windows and Android operating systems at the same time.

The threat actors use phishing as their attack vector to deliver malware to their targets, but the emails do not have any malicious files attached or direct malicious links included in the body of the email. The hackers attached a .txt file with details and short links, asking the targets to open it on smartphones and Windows machines.

If during the attack you get access to a shortened URL address, an encrypted .exe file and APK application will be downloaded via Dropbox, with each file performing a malicious function.

It was noted that the malicious emails were sometimes resent from a different email address with malicious files attached.

The downloaded malicious applications are disguised as image viewing tools and provide such functionality while the malware is installed.

Once the user installs the malware, it is run in the background mode and, if it is installed on the phone, records the victim's phone calls.

Recorded phone calls are sent to a preconfigured C&C server, which also allows the threat actors to download and launch additional malicious applications.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, and Red Eyes) is a North Korean cyberespionage group active since at least 2012. The group primarily targets South Korea, but also Japan, Vietnam, Russia, Nepal, China, India, Romania, Kuwait, and other regions.

APT name	Regions attacked	Operation start
Stealth Falcon	UAE, Saudi Arabia, Thailand, Netherlands	2019

Experts discovered a new backdoor that turned out to be linked to other malware by the Stealth Falcon group.

The detected malware was named Win32/Stealth Falcon. It works as a basic backdoor that allows its operators to download and run additional code on infected hosts or to exfiltrate data to remote servers.

In its communication with the C&C server, the Trojan uses the standard Windows component Background Intelligent Transfer Service (BITS), which is a rather unusual technique.

The BITS service works by detecting when the user is not using their network connection and downloads Windows updates during downtime. Other apps can also tap into the BITS system to download their own updates.

The experts detected several attacks with this Trojan in the UAE, Saudi Arabia, Thailand, and the Netherlands. In the latter case, the target was a diplomatic mission of a Middle Eastern country.

In their report on the group's activity, the specialists cited Amnesty International, which claimed that the Stealth Falcon group appears to be a private cybersecurity contractor named DarkMater, detailed in a January 2019 Reuters report.

The article described Project Raven, an initiative allegedly employing former NSA operatives who were helping the UAE government track and hack dissidents aiming at the same types of targets as Stealth Falcon. DarkMatter denied all accusations.

The Stealth Falcon group, also known as FruityArmor, has been active since 2012. It targets political activists and journalists in the Middle East.

APT name	Regions attacked	Operation start
Tortoiseshell	Saudi Arabia	July 2018

In September 2019, a hacker group that remained unnoticed since 2018, was detected. Over the last 14 months, the group—which was dubbed Tortoiseshell—has attacked at least 11 IT companies, most of them located in Saudi Arabia.

IT providers are an ideal target for attackers given their high level of access to their customers' computers. This access may enable threat actors to send malicious software updates to target machines and may even provide them with remote access to customer machines.

A unique component used by Tortoiseshell is a malicious program called Backdoor.Syskit. It can download and execute additional tools and commands. The actors behind it have developed it in both Delphi and .NET. Backdoor.Syskit is run with the "-install" parameter to install itself. The malware collects and sends the machine's IP address, operating system name and version, and Mac address to the C&C server using the URL in the Sendvmd registry key. Data sent to the C&C server are Base64-encoded.

APT name	Regions attacked	Operation start
BITTER	China	May 2019

Information security researchers discovered a phishing site impersonating a login page of the Ministry of Foreign Affairs of the People's Republic of China. When visitors attempt to login to the fraudulent page, they are presented with a pop-up verification message asking users to close their windows and continue browsing. Further analysis of the threat actors' infrastructure uncovered a broader phishing campaign targeting other government sites and state-owned enterprises in China.

The analysis revealed similarities with a previous campaign carried out by the BITTER group. By stealing email credentials and accessing internal email content, it would be possible to gain insight into what decisions are being made within the target organization, which could lead to the theft of sensitive information. Although it is difficult to pinpoint the exact motivation of the attackers, it is highly likely this campaign is to pursue some form of espionage. Most of the organizations being phished in these campaigns relate to economic trade, defense, aviation, and foreign relations.

The BITTER group has been active since at least 2015 and is believed to be working in the interests of India. The group's campaigns primarily target China, Pakistan, and Saudi Arabia. The group's arsenal includes the similarly named remote access Trojan BitterRAT and a family of malicious loaders called ArtraDownloader.

APT name	Regions attacked	Operation start
Patchwork	Pakistan	July 2018

Another Indian group called Patchwork was found to have launched a long-term campaign.

The attack vector is an .xlsm file ("India makes Kashmir Dangerous Place in the World.xlsm"), which exploits the CVE-2017-11882 vulnerability to release "MSBuild.exe" to the %AppData% directory and then add Run registry key to ensure persistent. To obtain the C&C address, it reads data from Github and Feed43 where the content can be controlled by the attackers.

The analysis revealed 44 configuration files hosted on Github and utilized by this APT group. Judging by the time of file creation, the attackers started working at least as early as July 2018. The earliest created account was on July 3, 2018. This continued until August 2019 when the document was completed.

The conflict between India and Pakistan over the territory of Kashmir has lasted for decades. It a perfect topic for targeted attacks in cyber warfare.

The Patchwork group (also known as Dropping Elephant, Chinastrats, APT-C-09, Monsoon, and Quilted Tiger) has been active since at least 2015 and attacks organizations in industries connected with diplomatic missions and governmental entities. The group's aims are espionage and information theft.

APT name	Regions attacked	Operation start
Emissary Panda	Global	September 2019

September 2019 saw new activity of the Emissary Panda group.

The new activity involved a binary titled "odbcad32.exe," which had the appearance of the legitimate Open Database Connectivity Data Source Administrator utility by Microsoft, but was not signed with a Microsoft certificate. Instead, the binary was signed with a certificate belonging to Hangzhou Bianfeng Networking Technology Co., Ltd. Research on this company name in open sources indicated that it is a Chinese software company and a subsidiary of the media organization Zhejiang Daily Digital, which is headquartered in Hangzhou, China.

Upon execution, the binary would elevate privileges and drop two files: "odbccx32.dll" in the C:\Windows\system32\ folder and a randomly named batch file in the user's local temp folder.

"Net.exe" was then launched with the parameters "stop "Remote Registry Configuration"". Next, "rundll32.exe" loads the aforementioned "odbccx32.dll," and then another "net.exe" is launched with the parameters "start "Remote Registry Configuration"". Once the malicious DLL is loaded via "rundll32.exe," it establishes persistence via a new service. Cmd.exe then executes the dropped batch file, which deletes the originally executed file, as well as the batch file itself. Following this, "Svchost.exe" is executed and loads the malicious file "odbccx32.dll."

The TTPs (Tactics, Techniques, and Procedures) observed in this sample are consistent with those seen in past attacks conducted by the Emissary Panda APT group, specifically in relation to the ZxShell Remote Access Trojan (RAT), which they have been observed using.

Emissary Panda (also known as APT27, TG-3390, Bronze Union, and Lucky Mouse) is a Chinese cybercriminal group known since 2010. The group targets aerospace, government, defense, technology, energy and manufacturing industries.

APT name	Regions attacked	Operation start
Poison Carp	Tibet	November 2018

Information security specialists uncovered the activity of a threat group they named Poison Carp, which used the popular messaging app WhatsApp in their attacks.

POISON CARP uses a total of eight Android browser exploits and one Android spyware kit, as well as one iOS exploit chain and iOS spyware.

The following exploits were used:

- CVE-2016-1646
- CVE-2016-5198
- CVE-2017-5030
- CVE-2017-5070
- CVE-2018-6065
- CVE-2018-17463
- CVE-2018-17480
- CVE-2019-5825

Posing as journalists or government officials in senior positions, the hackers started WhatsApp conversations with high-ranking persons. Once the attackers won their victims' trust, they sent them a link, which downloaded the spyware.

The MOONSHINE malware allowed the hackers to access calls, messages (including messaging apps installed on the device) and location information; control the device's microphone and camera; and install programs.

Citizen Lab said the main targets in the attack between November 2018 and May 2019 were senior members of Tibetan groups, with the hacking being aimed at provoking ethnic conflicts.

APT name	Regions attacked	Operation start
Rancor	South-East Asia	August 2019

In September 2019, an .rtf document was uploaded to VirusTotal. The document is written in Khmer, the official language of Cambodia, and lists the names of various government officials.

Opening this "official" document executes CVE-2018-0798 in the background. CVE-2018-0798 is an RCE vulnerability which allows a stack buffer overflow that can be exploited by a threat actor to perform stack corruption. This allows the attacker to create the file "OSEA54d.tmp" in the C:\Users[username]\AppData\Local\Temp folder and execute it.

Next, "OSEA54d.tmp" creates a .vbs script titled "Photo.vbs" in the C:\Windows\System32\spool\drivers\color\ folder.

The script will trigger the launch of “GoogleUpdate.exe” with the -f and -urlcache flags to force fetch a specified URL and update the cache. The URL provided (167.71.237.100/%ComputerName%.png) requests a file based off the user’s computer name, which is then stored in the user’s local temp folder as a .tmp file.

Next, “OSE91E4.tmp” launches two child cmd.exe processes. Cmd.exe calls schtasks to create a scheduled task called “Google-Updates,” which utilizes “msiexec” to execute the downloaded payload “[ComputerName].tmp” from the user’s local temp folder once every minute. This would be used to maintain persistence once the secondary payload was downloaded.

It was not possible to install the final payload, but based on the observed TTPs (Tactics, Techniques, and Procedures) it was suggested that this activity is related to Rancor APT. Therefore, the final payload would have likely been the DDKONG or PLAINTEE malware, which serve as backdoors, allowing the actors to list files, upload/download files, and execute other commands.

Rancor is a Chinese hacking group that carries out targeted campaigns against South-East Asia. The group has been active since at least 2017 and uses politics-related lures to make users open their malicious documents.

Data leaks

- In September 2019, it was reported that Lion Air, the biggest Indonesian airline, had a data breach. The company stored information on an unprotected Amazon server, which could be accessed from the outside without authorization. At the moment, it is unclear who had access to it first, but the data ended up on underground resources. The database contains information on 35 million customers of the airline, as well as data on Malindo Air, a subsidiary of Lion Air.
- A similar situation happened with Ecuadorian residents' data, which were stored on a misconfigured Elasticsearch server. The database contained 18 GB of personal data of virtually all Ecuadorian citizens (some of the data were taken from government sources, other parts—from private databases), including names, information on family members/trees, civil registration data, financial and work information, and data on car ownership—a total of 20.8 million records. It has been underscored that the database is up to date, containing information as recent as 2019. The Ecuadorian authorities arrested an employee of Novaestrat, the company responsible for the leak.
- Data of the customers of Sephora, a chain of personal care and beauty stores, were leaked in a major data breach. Group-IB specialists discovered these data on underground resources. The first database was published on two hacker forums on July 6 and 17, 2019. It contains 500,000 entries, including user names and hashed passwords for Sephora.co.id (Indonesia) and Sephora.co.th (Thailand). The second database appeared on an underground forum on July 28, 2019. It is believed that the leak occurred in March 2019. The database contains 3.2 million entries and includes logins, hashed passwords, registration dates, last active dates, IP, sex, first name, last name, ethnicity, eye color, skin colour, skin type, hair color, hair problems, etc. This set of data is sold at US$1,900. Even though the leaks do not contain any payment information or decrypted passwords, they can be used in spear-phishing attacks with social engineering techniques.
- Capital One, a US bank, was reported to have had a data breach that affected over 100 million people who applied for credit cards between 2005 and 2019. As a result, third parties got access to information that included names, addresses, zip codes/postal codes, phone numbers, email addresses, dates of birth, and self-reported income. The bank said that in order to hack into Capital One's network, the threat actor exploited a "configuration vulnerability," which was fixed on July 19 immediately after the breach was detected. The suspect, who has already been arrested, is Paige A. Thompson (also known as Erratic), a 33-year-old resident of Seattle and a former Amazon Web Services employee. The US Department of Justice said Thompson mentioned the compromise on GitHub. FBI agents searched Thompson's house and seized electronic storage devices containing a copy of the data stolen from Capital One.
- In late July 2019, a number of media outlets reported that SyTech, a Moscow-based company, had been hacked. On July 13, attackers breached SyTech's Active Directory server, from where they gained access to the company's entire IT network. The hackers stole 7.5 TB of data and defaced the company's website. The documents received by BBC Russia reveal that the company has been involved in at least 20 non-public IT projects commissioned by Russian special service agencies and departments.

  The company is an FSB (Russia's Federal Security Service) contractor. The hackers, who go by the alias 0v1ru$, posted attack-related screenshots on Twitter and later shared the stolen data with Digital Revolution, another hacking group. Analysis of this breach found that the stolen information was not publically available.
- On August 20, Imperva, a cybersecurity and DDoS mitigation company, reported a breach. The data compromise affected customers who registered on Imperva Cloud Web Application Firewall

before September 15, 2017. Detailed information about the incident is unavailable as Imperva does not comment on the situation citing an ongoing investigation.